

Two Cloudflare rules for the Azalea domains

TLS certificate renewal on both origin servers has been failing since July. The cause is Cloudflare bot protection blocking the validation requests. Two scoped rules fix it.

DOMAINS	CLOUDFLARE ZONE	ORIGIN
azaleabaguio.com	rick.ns.cloudflare.com	192.249.125.21
azaleaboracay.com	walk.ns.cloudflare.com	InMotion Hosting

RAISED BY
Online Creative Solutions
Web maintenance

What is happening

Both domains proxy through Cloudflare. The Let’s Encrypt certificates on the origin servers renew by answering a challenge file over HTTP — and that request is being answered with **403 Forbidden** before it reaches the server.

The request originates from the hosting server’s own IP, which is a datacenter address. Cloudflare’s bot protection scores those aggressively. The same URL, same file, same filename pattern returns correctly from an ordinary residential connection:

REQUEST	FROM	RESULT
Challenge file that exists	Residential connection	200 OK
Challenge file that does not exist	Residential connection	404
Same path, direct to origin (Cloudflare bypassed)	Residential connection	200 OK
Certificate validation	Hosting server (datacenter IP)	403
Site management API	Hosted app (datacenter IP)	Bot challenge

The path itself is not blocked and the origin is configured correctly. Only requests from datacenter addresses are refused, which is why this looks like a server fault but is not one.

CONFIRM THIS YOURSELF IN ABOUT A MINUTE

Cloudflare dashboard → **Security** → **Events**, filter `Path` contains `/.well-known/`. The blocked validation attempts will be listed with the rule or service that stopped them.

What we are asking for

Two WAF custom rules, both narrow. Neither weakens protection for ordinary visitor traffic, and neither grants access to anything — every endpoint involved still enforces its own authentication.

1 Let certificate validation through

Fixes the expiring certificates. This is standard Cloudflare practice.

WAF → **Custom rules** → **Create rule**, applied to both zones:

RULE EXPRESSION

```
(starts_with(http.request.uri.path, "/.well-known/acme-challenge/")  
or starts_with(http.request.uri.path, "/.well-known/pki-validation/"))
```

Action: **Skip** → select *All remaining custom rules*, and under *Additional options* also skip **Bot Fight Mode / Super Bot Fight Mode**.

These two paths exist only to serve short-lived, randomly-named text files that certificate authorities read to confirm domain control. They expose nothing, and every ACME client on the internet needs them reachable.

2 Let the maintenance panel reach the management endpoint

Restores automated updates, security scans and inventory for these sites.

OCS maintains these sites through a WordPress plugin endpoint. Since the sites moved behind Cloudflare, every automated call is challenged, so plugin updates, malware scans and uptime checks no longer run for these two domains.

RULE EXPRESSION

```
(http.request.uri.path contains "/wp-json/mcp/novamira"
and http.user_agent eq "wp-control-panel-mcp/1.0")
```

Action: **Skip** → *All remaining custom rules* + **Bot Fight Mode**, same as above.

The User-Agent above is published in our source repository, so it is guessable by design. If you would rather the rule matched on something unguessable, option B below is stronger and we would prefer it too.

2B Preferred: match a shared secret instead of the User-Agent

Same rule, unguessable match. Choose this *or* rule 2, not both.

We generate a random 32-byte value, send it on every request in a private header, and you match on that instead. Nothing about it is published, so nobody can reproduce the request by reading our code.

RULE EXPRESSION

```
(http.request.uri.path contains "/wp-json/mcp/novamira"
and http.request.headers["x-ocs-panel-key"][0] eq "<SECRET>")
```

Action: **Skip** → *All remaining custom rules* + **Bot Fight Mode**.

Tell us you want this and we will send the secret over a channel of your choosing. It can be rotated at any time — we change our side, you update the rule.

Why we are not asking for an IP allowlist

An allowlist under *Security* → *WAF* → *Tools* → *IP Access Rules* would normally be the cleanest answer here, and it is the first thing a security-minded administrator will suggest. It is not available in this case, and the reason is worth stating plainly rather than leaving you to discover it.

Our panel runs on Vercel's shared tier, whose functions egress from rotating cloud addresses. Fixed egress IPs are an Enterprise-plan feature we do not have. The only "allowlist" we could offer would be a broad cloud provider range covering thousands of unrelated tenants — weaker than either rule above, and you would be right to refuse it.

If an IP match is a hard requirement on your side, tell us and we will price moving the panel onto infrastructure with a dedicated address.

What rule 2 does and does not do

Either version skips the *bot challenge* only. It does **not** grant access: the endpoint still requires a WordPress application password, and an unauthenticated request answers `401 rest_forbidden` with or without the rule.

The exposure it adds is that a request carrying the matching header reaches the login check directly instead of being challenged first — the same position as any site not behind Cloudflare. With option 2B that request is one nobody else can construct.

One thing to be aware of

The origin certificates have already expired

Visitors are unaffected — Cloudflare is terminating TLS at the edge with its own valid certificate, which is why nothing looks broken.

DOMAIN	ORIGIN CERTIFICATE EXPIRED
azaleabaguio.com	14 Aug 2026
azaleaboracay.com	10 Jul 2026

This means the zones cannot currently be on **Full (strict)** SSL — strict mode validates the origin certificate and both sites would already be down.

Until rule 1 is in place and the certificates renew, please do not switch SSL mode to Full (strict) and do not move these domains off Cloudflare. Either would take both sites offline immediately.

Once renewal works, Full (strict) becomes available and is the more secure setting. If you would rather not depend on Let's Encrypt through the proxy at all, a Cloudflare **Origin CA certificate** (*SSL/TLS → Origin Server*) is valid for 15 years and solves it permanently — we can install it on the hosting side.

What we need back

1. Confirmation that rule 1 is live, so we can trigger certificate renewal.
 2. For rule 2 — tell us whether you want the User-Agent version (2) or the shared secret (2B). If 2B, name a channel and we will send the secret.
 3. The current SSL/TLS encryption mode for both zones (*SSL/TLS → Overview*), so we know whether the origin certificates are load-bearing today.
- Both rules are reversible and scoped to a single path each. Happy to get on a call and make the changes together if that is easier than working from a document.

Prepared by Online Creative Solutions · web maintenance for azaleabaguio.com and azaleaboracay.com.

All findings above were measured directly against the live sites. Figures current as of 31 August 2026.